

PORTFOLIO PROJECT

Secure Medical Clinic Azure Environment

Security-focused Azure foundation aligned to AZ-900 concepts

Project	Implementation
Author	Jaiprakash Reddy
Region	Australia East
Environment	Development portfolio lab
Data handling	Fictitious medical records only
Prepared	25 August 2026

No production patient data • No public RDP or SSH • Low-cost design

Executive summary

This project demonstrates the design and governance of a secure, low-cost Azure environment for a fictitious medical clinic. It focuses on identity, network segmentation, storage protection, monitoring, policy, and operational safeguards. No compute workload or production healthcare information was deployed; the result is a reusable security foundation and evidence-based portfolio case study.

Outcome	Evidence
Cost control	A\$5 monthly budget configured at resource-group scope
Network segmentation	Three /24 subnets with dedicated NSGs
Identity	Microsoft Entra groups and scoped Azure RBAC
Data protection	Private blob container, TLS 1.2, Entra authorization, network restriction
Detection	Activity Log alert delivered through an email action group
Governance	Delete lock and deny policy for a required project tag

Objectives and constraints

- Apply AZ-900 concepts through a practical Azure deployment.
- Use free or low-cost control-plane services and avoid always-on compute.
- Never expose RDP (3389) or SSH (22) directly to the internet.
- Use only fictitious records and conceal subscription IDs, object IDs, emails, and personal details in public evidence.
- Avoid Azure Bastion, VPN Gateway, ExpressRoute, Azure Firewall, and NAT Gateway.

Architecture

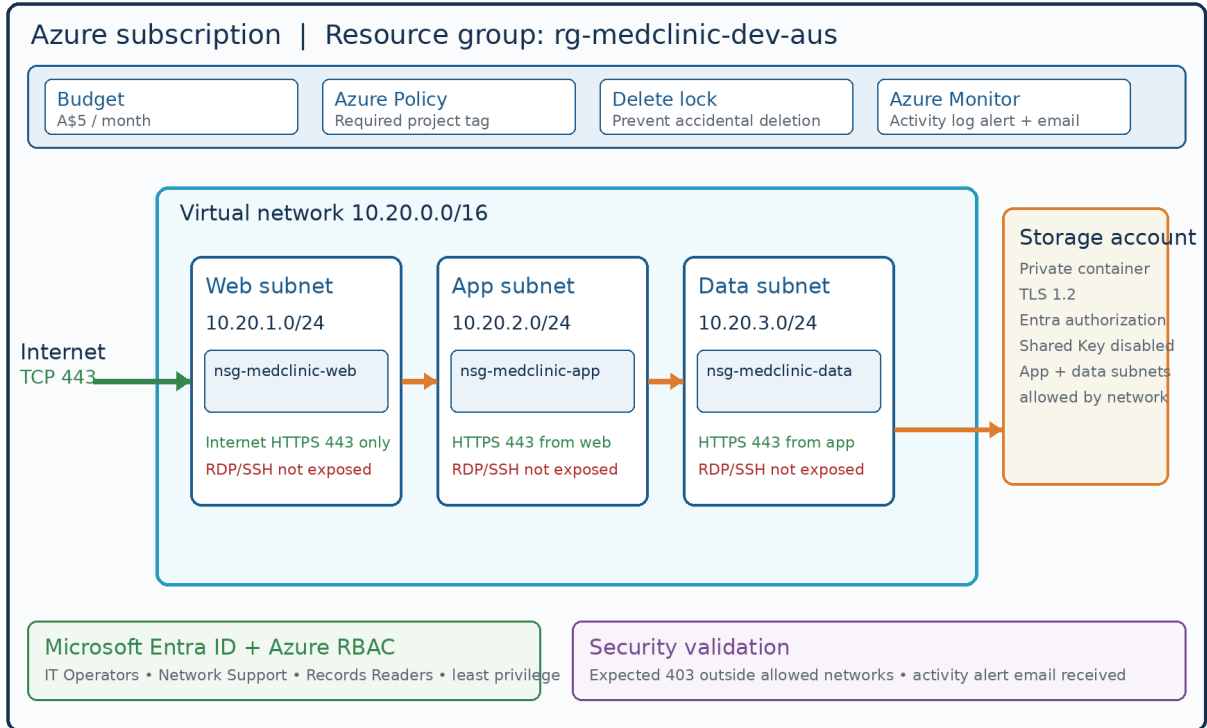


Figure 1. Logical security architecture. The web, app, and data tiers are network segments; no production application servers were deployed.

Resource inventory

Type	Name	Purpose
Resource group	rg-medclinic-dev-aus	Governance boundary
Virtual network	vnet-medclinic-dev-aus	10.20.0.0/16
Web subnet	snet-web	10.20.1.0/24
App subnet	snet-app	10.20.2.0/24
Data subnet	snet-data	10.20.3.0/24
Network security groups	nsg-medclinic-web / app / data	One NSG per subnet
Storage account	stmedclinicdev0207	Private fictitious records
Monitor	alert-medclinic-nsg-change	Email via ag-medclinic-security
Governance	Policy + delete lock	Required tag and deletion protection

Network security design

Tier	Allowed inbound	Additional control
Web	TCP 443 from Internet	Explicitly deny Internet RDP/SSH and other Internet traffic
App	TCP 443 from 10.20.1.0/24	Deny other VirtualNetwork traffic
Data	TCP 443 from 10.20.2.0/24	Deny other VirtualNetwork traffic

Azure NSGs are stateful and evaluate lower priority numbers first. Dedicated NSGs reduce blast radius and make the intended web → app → data flow reviewable. AzureLoadBalancer service-tag exceptions were added above the custom VirtualNetwork deny rules so Azure platform health traffic is not unintentionally blocked.

Storage security

- Private container clinic-records containing only a fictitious CSV.
- Secure transfer required; minimum TLS version 1.2.
- Blob anonymous access disabled; Shared Key access disabled.
- Microsoft Entra authorization used for data access.
- Blob and container soft delete enabled for seven days.
- Public network access restricted to selected virtual-network subnets; an external portal request returned the expected HTTP 403.

Identity and access management

Principal	Role	Scope
MedClinic-IT-Operators	Contributor	Resource group
MedClinic-Network-Support	Network Contributor	Resource group
MedClinic-Records-Readers	Storage Blob Data Reader	Storage account
Project owner	Storage Blob Data Contributor	Storage account

This separates management-plane permissions from storage data-plane permissions and demonstrates least privilege through group-based access.

Monitoring, governance, and cost

Monitoring

An Azure Monitor Activity Log alert detects NSG changes and routes notifications through ag-medclinic-security. The action group was validated when an email notification arrived after a controlled NSG tag change.

Governance

A CanNotDelete resource lock protects the resource group from accidental deletion. Azure Policy uses a Deny effect to require the project tag and value on resources. The compliance view initially showed 6 of 7 resources compliant because the action group lacked the tag. After remediation, policy reevaluation may take time; the 86% screenshot is retained as evidence of detection and corrective action rather than presented as a failure.

Cost controls

A monthly A\$5 budget was configured. The lab avoids charge-generating gateways, Bastion, public IPs, and always-on VMs. Budgets alert on spend but do not automatically stop resources, so cleanup remains essential.

Security validation results

Test	Observed evidence	Result
No public remote administration	NSGs contain no Internet allow rule for ports 22 or 3389	Pass
Tier segmentation	Web, app, and data each use a dedicated subnet and NSG	Pass
Web exposure	Only TCP 443 is allowed from Internet	Pass
App restriction	TCP 443 allowed only from web subnet; other VNet traffic denied	Pass
Data restriction	TCP 443 allowed only from app subnet; other VNet traffic denied	Pass

Storage anonymity	Blob anonymous access disabled	Pass
Storage network test	External portal access returned HTTP 403	Pass
Detection	Activity Log alert email received	Pass
Policy remediation	Missing tag detected and corrected; reevaluation pending in captured view	Pass with note

Problems found and corrected

- NSG association was reviewed and corrected so each subnet has its own matching NSG.
- Early app/data NSG rules were overly broad or had misleading names; source CIDRs, actions, and priorities were corrected.
- Custom VirtualNetwork deny rules triggered Azure warnings; explicit AzureLoadBalancer allows were placed at a higher priority.
- Azure Policy identified an untagged action group; the required project tag was added.

AZ-900 concepts demonstrated

Domain	Applied concept
Cloud concepts	Consumption awareness, shared responsibility, and service scope
Architecture and services	Region, subscription, resource group, VNet, subnet, NSG, storage
Identity	Microsoft Entra ID, groups, Azure RBAC, management vs data plane
Management and governance	Tags, Azure Policy, resource locks, budgets, Azure Monitor
Security	Defense in depth, least privilege, segmentation, encryption in transit, private data access

Limitations and future improvements

- Deploy a small application workload only if needed, with no public management ports.
- Replace selected-network storage access with a private endpoint and private DNS for a production design.
- Manage secrets with Azure Key Vault and managed identities.
- Evaluate Defender for Cloud, Log Analytics, Microsoft Sentinel, Conditional Access, MFA, and PIM based on licensing and cost.
- Rebuild the environment with Bicep or Terraform and validate with automated tests.
- Use a production-grade backup, recovery, data-retention, and regulatory program before handling real health information.

Résumé bullets

- Designed a secure Azure portfolio environment using a three-tier VNet (web, app, and data subnets) with dedicated NSGs, least-privilege traffic rules, and no public RDP/SSH exposure.
- Hardened Azure Blob Storage using private containers, TLS 1.2, Microsoft Entra authorization, disabled Shared Key and anonymous access, seven-day soft delete, and selected-network restrictions.
- Implemented Microsoft Entra groups and scoped Azure RBAC for Contributor, Network Contributor, Storage Blob Data Reader, and Storage Blob Data Contributor access.
- Configured Azure Monitor Activity Log alerts and an email action group; validated detection through a controlled NSG change and successful notification.

- Applied Azure governance with tags, a deny policy, a resource-group delete lock, and an A\$5 monthly budget; remediated policy and NSG configuration findings during security testing.

LinkedIn project description

I built a Secure Medical Clinic Azure Environment as a hands-on portfolio project while developing my AZ-900 knowledge. The lab uses only fictitious data and demonstrates a three-tier virtual network, dedicated Network Security Groups, hardened Blob Storage, Microsoft Entra groups, scoped Azure RBAC, Activity Log alerts, email notifications, resource locks, Azure Policy, tags, and cost controls. I also tested expected-deny scenarios, corrected NSG and tagging issues, and documented the results as a security case study. No RDP or SSH was exposed to the internet, and the environment avoided high-cost gateway services and always-on compute.

#Azure #AZ900 #CloudSecurity #MicrosoftEntra #Cybersecurity #AzureMonitor #AzurePolicy

Evidence checklist

- Budget list showing A\$5 monthly limit
- Resource group overview and tags
- VNet address space and three subnets
- Subnet list with one-to-one NSG associations
- Inbound rules for web, app, and data NSGs
- Storage configuration and expected HTTP 403
- Entra groups and RBAC assignments
- Activity Log alert, action group, and received email
- Azure Policy compliance and remediation
- Resource-group delete lock

Privacy reminder: Before publishing screenshots, conceal subscription IDs, tenant/object IDs, correlation IDs, email addresses, account names, and other personal information.

Official Microsoft documentation

Virtual networks: <https://learn.microsoft.com/azure/virtual-network/virtual-networks-overview>

Network security groups: <https://learn.microsoft.com/azure/virtual-network/network-security-groups-overview>

Storage network security: <https://learn.microsoft.com/azure/storage/common/storage-network-security>

Azure RBAC: <https://learn.microsoft.com/azure/role-based-access-control/overview>

Azure Monitor activity log: <https://learn.microsoft.com/azure/azure-monitor/essentials/activity-log>

Resource locks: <https://learn.microsoft.com/azure/azure-resource-manager/management/lock-resources>

Azure Policy: <https://learn.microsoft.com/azure/governance/policy/overview>

Cost budgets: <https://learn.microsoft.com/azure/cost-management-billing/costs/tutorial-acm-create-budgets>

Cleanup handoff

After final evidence is captured: remove the delete lock, delete rg-medclinic-dev-aus, verify deletion and cost status, then remove the fictitious Entra users and groups. Cleanup is intentionally handled as the final guided stage so evidence is not lost prematurely.